

ResolvX

Password Policy

Topic-Specific Policy - Credential Hygiene (Supplements POL-003)

POL-012 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-012
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	IT Admin
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A5.17, A8.5 · NIST CSF 2.0 PR.AA-01 · SOC 2 CC6.1

1. Purpose

This Password Policy establishes ResolvX's credential hygiene practices on how passwords are stored, monitored for compromise, and handled for the account types that need practices beyond standard day-to-day login.

Password complexity, MFA requirements by account type, session timeouts, and account lockout are already fully defined in the Access Control Policy (POL-003) §5 and remain governed there. This policy exists to cover what POL-003 does not: how credentials are stored and managed day to day, how ResolvX detects a password that has already been compromised, and how the highest-sensitivity credentials (break-glass, service accounts) are physically and operationally handled.

2. Scope

This policy applies to all ResolvX personnel and to the following credential types specifically:

- Personal login credentials for any ResolvX system.
- Break-glass / emergency account credentials.
- Service account and API credentials.

For MFA requirements, password complexity rules, session timeouts, and account lockout thresholds, see POL-003 §5.1–§5.4, this policy does not restate them.

3. Password Manager Mandate

All ResolvX credentials that are not authenticated through Okta SSO must be stored in 1Password (the company-managed password manager), not in a browser's built-in credential store, a spreadsheet, a note-taking app, or written down.

- Every credential stored in 1Password must be unique, no reuse of a password across two ResolvX systems, and no reuse of a personal password for any ResolvX system.
- 1Password's built-in password generator is used for any newly created credential rather than a self-chosen password, so generated passwords meet POL-003's complexity bar without relying on individual judgement.
- Departing personnel's 1Password vault access is revoked as part of offboarding, coordinated with IT Admin per POL-011 §8.

4. Credential Breach Monitoring

Waiting for a user to report a compromised password is not a detection strategy. ResolvX monitors for compromised credentials proactively:

- 1Password Watchtower flags reused, weak, or breach-exposed passwords across the organization's vaults, reviewed monthly by IT Admin.
- Okta ThreatInsight blocks and flags authentication attempts associated with known-compromised credentials or credential-stuffing patterns.
- A flagged credential requires immediate reset, regardless of whether unauthorized access is confirmed. The exposure itself is the trigger, not proof of misuse.

5. Break-Glass Credential Handling

POL-003 defines break-glass accounts as requiring approval and full logging. This policy defines how their credentials are physically and operationally protected between uses:

- Break-glass credentials are split-knowledge where practical (no single individual holds the complete credential alone) or stored in a dedicated, restricted 1Password vault with access logged separately from standard vaults.
- Every break-glass credential is rotated immediately after each use, not left unchanged until the next scheduled review.
- Use of a break-glass credential triggers the same-day notification already required under POL-003 §7, plus a rotation confirmation logged by IT Admin.

6. Service Account & API Credential Hygiene

POL-003 requires service account credentials to rotate on a documented schedule; this policy sets that schedule where none is otherwise defined by the underlying platform:

Credential Type	Rotation Cadence	Trigger for Immediate Rotation
Service account passwords / secrets	90 days	Personnel change with prior access to the credential; suspected exposure
API keys (long-lived)	90 days, or platform default if shorter	Personnel change; suspected exposure; vendor security advisory
Certificate-based credentials	Per certificate expiry, monitored for upcoming expiry	Suspected private key exposure

7. Roles & Responsibilities

7.1 IT Admin

- Owns this policy and the 1Password administration console.
- Reviews Watchtower findings monthly (§4) and confirms remediation of flagged credentials.
- Manages break-glass vault access and confirms post-use rotation (§5).

7.2 DevSecOps

- Owns service account and API credential rotation for production systems (§6).

7.3 All Personnel

- Store all non-SSO credentials in 1Password; never in a browser, spreadsheet, or note-taking app.
- Reset any credential flagged by Watchtower or Okta ThreatInsight immediately upon notification.

8. Compliance and Enforcement

Storing a ResolvX credential outside 1Password, reusing a password across systems, or failing to rotate a break-glass credential after use is treated as a policy violation under POL-002's disciplinary process. Failure to complete scheduled service account rotation (§6) is logged as a Corrective Action Plan item.

9. Document Control

Policy ID	POL-012
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	IT Admin
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A5.17, A8.5 · NIST CSF 2.0 PR.AA-01 · SOC 2 TSC CC6.1
Related Documents	POL-002 (Acceptable Use Policy), POL-003 (Access Control Policy: Governs MFA, complexity, sessions, lockout), POL-011 (Asset Management Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		